Vulnerability Report

thc.cybersapiens.in

By

Suyash Ajay Gunjal

17CF - Batch

suyashagunjal@gmail.com

CyberSapiens

THE CYBER SECURITY EXPERTS

Content

SR.No	Vulnerability Name
1.	Business Logic Vulnerability – Price manipulation
2.	Sensitive Information Disclosure in Source Code
3.	Adding Non-existing Product in My-Cart Business Logic Vulnerability
4.	IDOR on Dashboard – Product Search
5.	File path traversal leads to reading local files
6.	Captcha Authentication Bypass
7.	CSRF – Logout Vulnerability
8.	CSRF Password Change Vulnerability
9.	Internal Broken Link Hijacking
10.	External Broken Link Hijacking

Vulnerability No.1

Business Logic Bug - Price manipulation

Bug Description:
A price manipulation vulnerability was identified on the shopping page. While adding a product to the cart, the product price can be modified by altering the request parameters. This allows an attacker to purchase items at an arbitrary price, which could result in financial loss for the organization.

Vulnerable Website URL: https://thc.cybersapiens.in

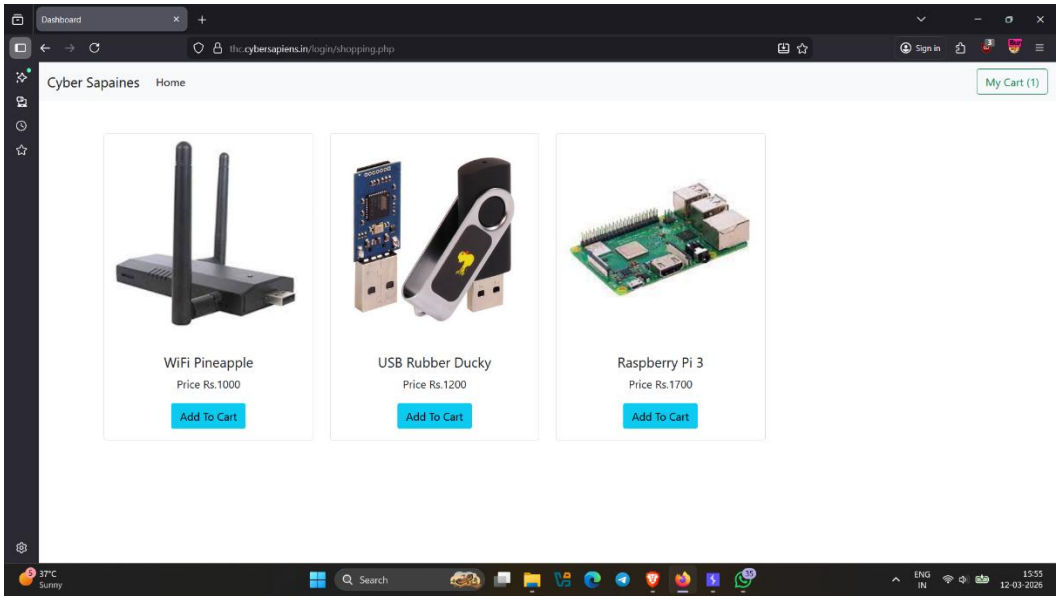
Threat
Price manipulation vulnerabilities occur when an application does not adequately verify pricing or cart-related parameters on the server side. In such cases, attackers can tamper with these values to alter product prices, reduce the total payable amount, or eliminate shipping fees. This weakness can lead to unauthorized purchases and financial impact for the business.

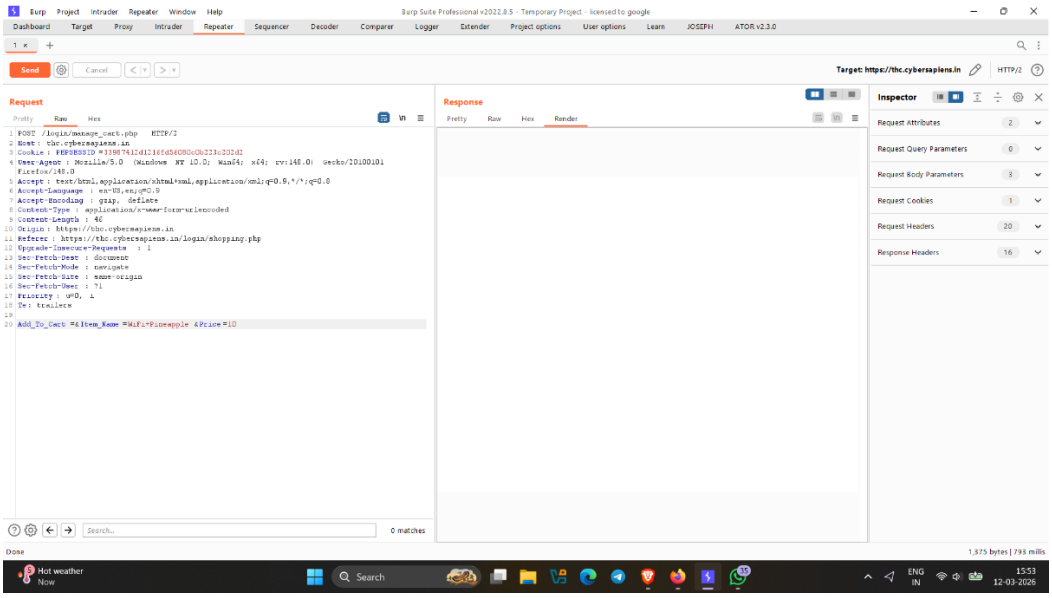
Steps to Reproduce

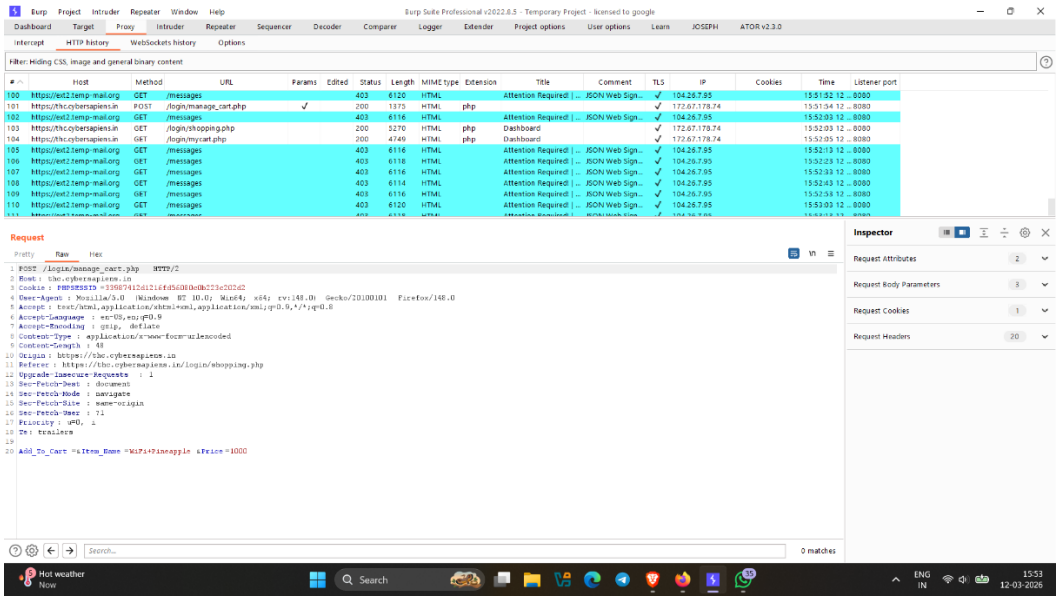
1. Browse to the application shopping page: http://thc.cybersapiens.in/login/shopping.php.
2. Add any product to the cart.
3. Intercept the outgoing request using **Burp Suite**.
4. Identify the parameter responsible for the product price in the request.
5. Modify this parameter to a lower value (e.g., 0) before forwarding the request.
6. After forwarding, navigate to the **My Cart** page.
7. Observe that the product price has been changed to the manipulated value, allowing the user to proceed with checkout using the altered price.

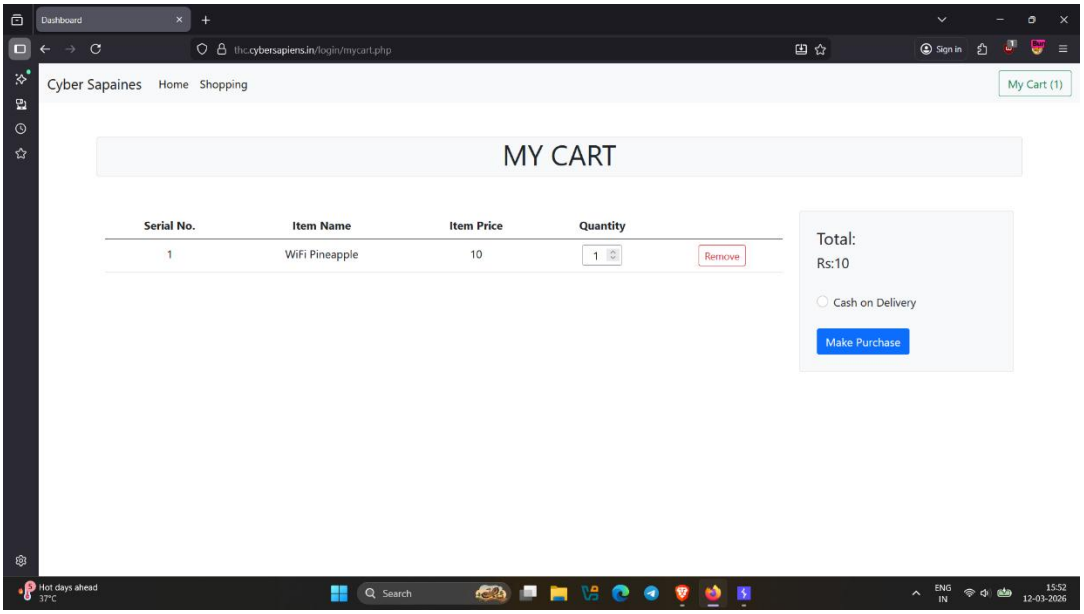
POC

1. Please refer video - https://drive.google.com/drive/folders/1whSEZCixapU7iNsyF3a68_XuziO493V6?usp=drive_link
2. Screenshots


Dashboard
thc.cybersapiens.in/login/shopping.php
Cyber Sapaines
Home
My Cart (1)
WiFi Pineapple
Price Rs.1000
Add To Cart
USB Rubber Ducky
Price Rs.1200
Add To Cart
Raspberry Pi 3
Price Rs.1700
Add To Cart


Burp Suite Professional v2022.8.5 - Temporary Project - licensed to google
Request
Response
Inspector
Add_To_Cart =&Item_Name =WiFi+Pineapple &Price =10


Burp Suite Professional v2022.8.5 - Temporary Project - licensed to google
Request
Inspector
Add_To_Cart =&Item_Name =WiFi+Pineapple &Price =1000



Remediation Actions

1. Validate Sensitive Parameters on the Server
   Product pricing and cart values should always be verified against the server database before processing transactions.

2. Minimize Trust in Client Inputs
   Inputs received from the client should never be trusted. All critical logic related to pricing must be handled server-side.

3. Implement Data Integrity Controls
   Introduce mechanisms such as secure tokens or encrypted parameters to prevent unauthorized modification of transaction data.

4. Monitor for Suspicious Activity
   Maintain logs for cart updates, price changes, and checkout operations to detect possible abuse attempts.

5. Perform Routine Security Assessments
   Regular penetration testing and security audits help identify vulnerabilities before attackers can exploit them.

6. Use Secure Communication Protocols
   Ensure that all application traffic is protected using HTTPS to maintain confidentiality and integrity of transmitted data.

Impact

- Attackers can manipulate product prices, leading to significant financial losses.
- Shipping charges may be bypassed through parameter tampering.

- Weak coupon validation could allow repeated or unauthorized discount usage.
- Modified cart data may compromise order accuracy and overall system integrity.

Reference:

https://medium.com/@nidhikathayat03/price-manipulation-vulnerability-in-e-commerce-applications-3852800b5e69

Vulnerability No.2

Sensitive Information Disclosure in Source Code

Bug Description
Sensitive information was identified in the application's source code comments. This information exposes a reference that allows unauthorized access to an internal restricted video.

Vulnerable Website URL: https://thc.cybersapiens.in

Threat
Information disclosure vulnerabilities arise when a website unintentionally exposes sensitive information such as internal resources, system details, or hidden links. Attackers can use this information to access restricted content or gain insights into the application's internal structure.

Steps to Reproduce

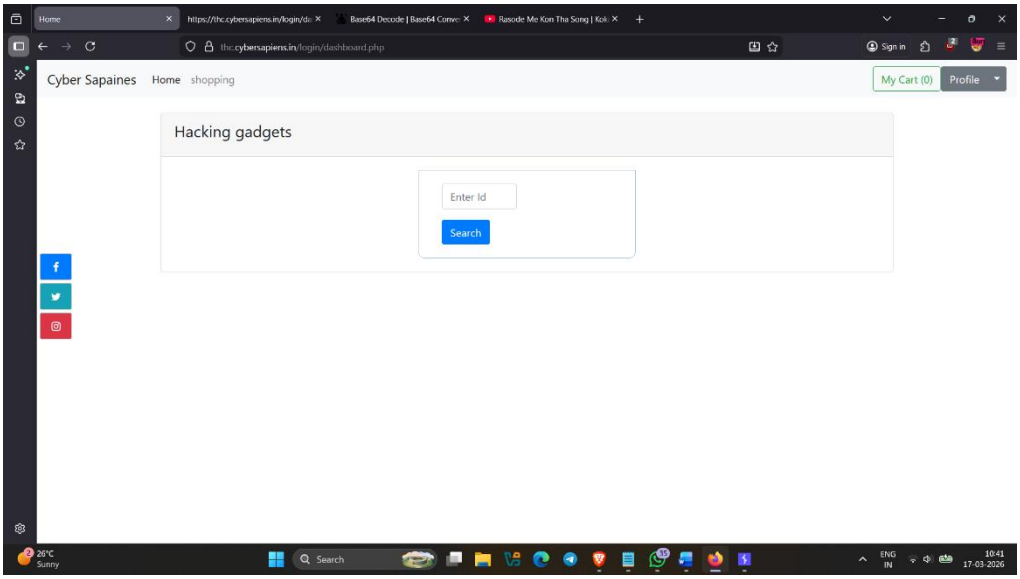
1. Access the login portal at https://thc.cybersapiens.in/login.
2. The application redirects to https://thc.cybersapiens.in/login/login.php.
3. Log in with valid credentials and navigate to the dashboard located at: https://thc.cybersapiens.in/login/dashboard.php.
4. Right-click on the page and select **View Page Source**.
5. Identify the following HTML comment embedded in the source code:

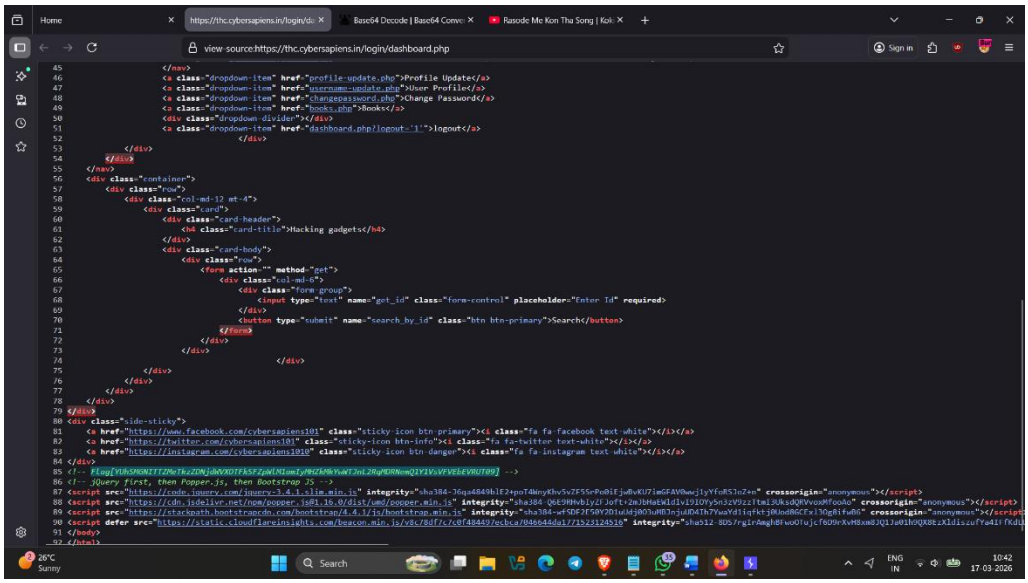
<!--Flag[YUhSNITTZMeTkzZDNjdWVXOTFkSFZpWlM1amIyMHZkMkYwWTJnLMD]-->

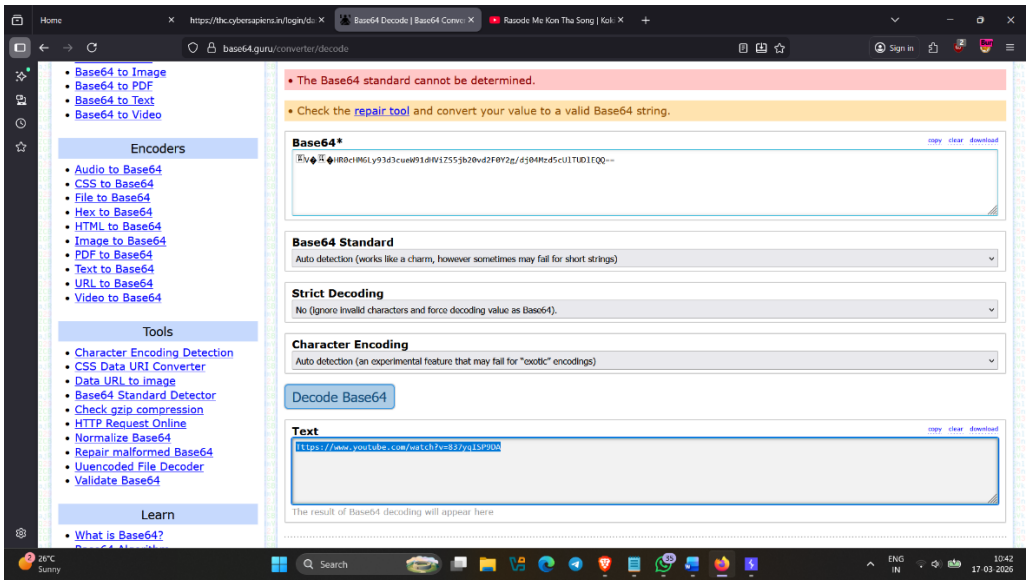
6. Copy the encoded string and decode it using a **Base64 decoder**.
7. The decoded output generates another Base64 string, which must be decoded again.
8. After performing the second decoding, the final result reveals a URL pointing to the restricted video.

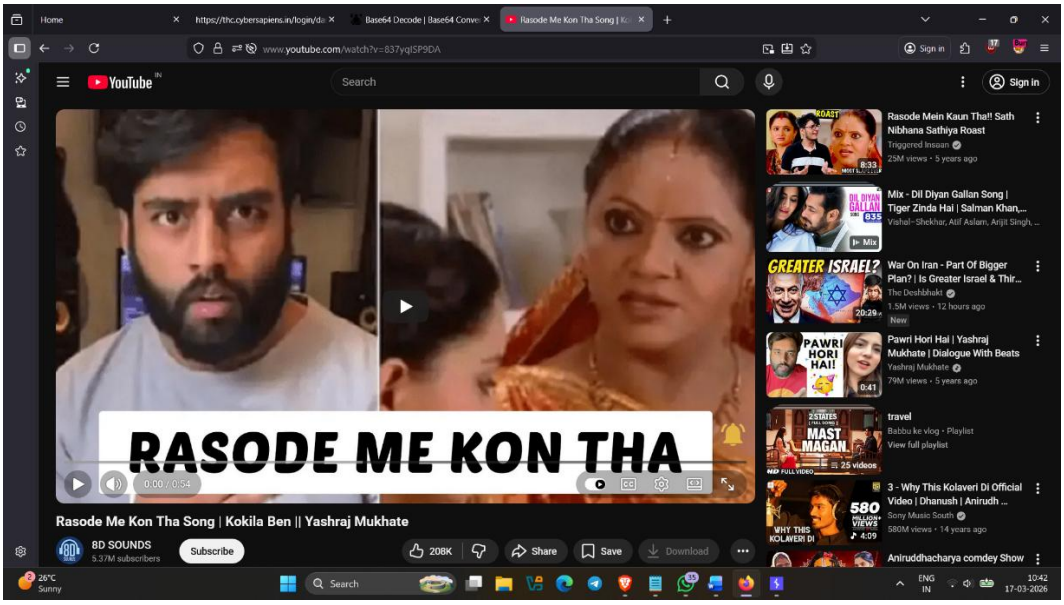
POC

1. Please refer video - https://drive.google.com/drive/folders/1whSEZCixapU7iNsyF3a68_XuziO493V6?usp=drive_link
2. Screenshots


Home
https://thc.cybersapiens.in/login/da
Base64 Decode | Base64 Conve
Rasode Me Kon Tha Song | Koli
thc.cybersapiens.in/login/dashboard.php
Sign in
Cyber Sapaines
Home
shopping
My Cart (0)
Profile
Hacking gadgets
Enter Id
Search
26°C
Sunny
Search
ENG
IN
10:41
17-03-2026


Home
https://thc.cybersapiens.in/login/da
Base64 Decode | Base64 Conve
Rasode Me Kon Tha Song | Koli
view-source:https://thc.cybersapiens.in/login/dashboard.php
Sign in
26°C
Sunny
Search
ENG
IN
10:42
17-03-2026


Home
https://thc.cybersapiens.in/login/da
Base64 Decode | Base64 Conve
Rasode Me Kon Tha Song | Koli
base64.guru/converter/decode
Sign in
Base64 to Image
Base64 to PDF
Base64 to Text
Base64 to Video
Encoders
Audio to Base64
CSS to Base64
File to Base64
Hex to Base64
HTML to Base64
Image to Base64
PDF to Base64
Text to Base64
URL to Base64
Video to Base64
Tools
Character Encoding Detection
CSS Data URI Converter
Data URL to image
Base64 Standard Detector
Check gzip compression
HTTP Request Online
Normalize Base64
Repair malformed Base64
Uuencoded File Decoder
Validate Base64
Learn
What is Base64?
• The Base64 standard cannot be determined.
• Check the repair tool and convert your value to a valid Base64 string.
Base64*
copy clear download
Base64 Standard
Auto detection (works like a charm, however sometimes may fail for short strings)
Strict Decoding
No (ignore invalid characters and force decoding value as Base64).
Character Encoding
Auto detection (an experimental feature that may may fail for "exotic" encodings)
Decode Base64
Text
copy clear download
https://www.youtube.com/watch?v=83Yqi5P9OA
The result of Base64 decoding will appear here
26°C
Sunny
Search
ENG
IN
10:42
17-03-2026



Impact

- Exposure of sensitive information may allow attackers to gain unauthorized access to restricted resources.
- Disclosure of internal details can assist attackers in understanding the system architecture.
- Such information may be used to identify and exploit additional vulnerabilities in the application.
- Even seemingly minor information leaks can increase the application's overall security risk.

Remediation Actions

- **Follow Secure Coding Practices**
  Developers should ensure that sensitive information is not included in source code comments. Internal references, credentials, hidden URLs, or any confidential data should be removed from publicly accessible code.
- **Review Source Code Before Deployment**
  Conduct code reviews to identify and eliminate comments or debug information that may disclose internal details.

Reference

https://medium.com/@ajay.monga73/understanding-information-disclosure-vulnerability-types-causes-and-mitigation-strategies-and-ef3fba195ac1

Vulnerability No.3

Adding Non-existing Product in My-Cart Business Logic Vulnerability

Bug Description
The application does not properly validate product information before adding items to the cart. By intercepting and altering the request parameters, it is possible to insert a random or non-existent product into the cart. This demonstrates a lack of server-side verification for product availability.

Brief / Threat
Business logic flaws are security weaknesses that occur due to errors in the design of an application's workflow. Instead of exploiting technical vulnerabilities, attackers take advantage of normal application behavior in unintended ways. These issues typically arise when developers do not anticipate abnormal scenarios or fail to implement appropriate validation checks.

Vulnerable Website URL:

https://thc.cybersapiens.in/login/manage_cart.php

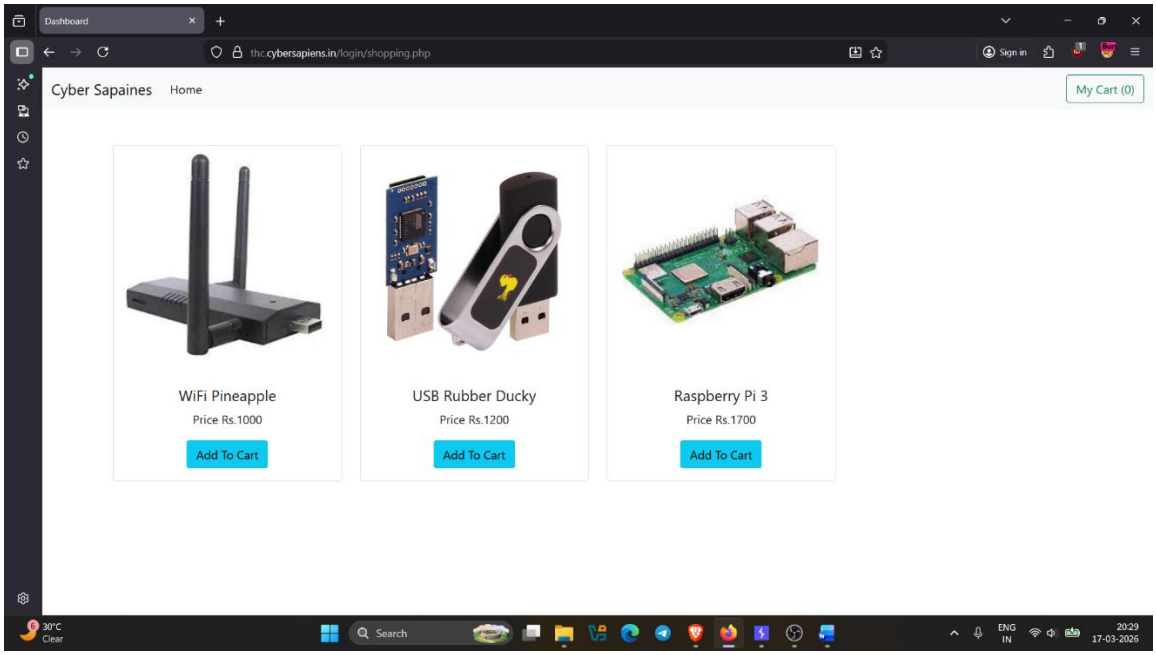
Steps to Reproduce

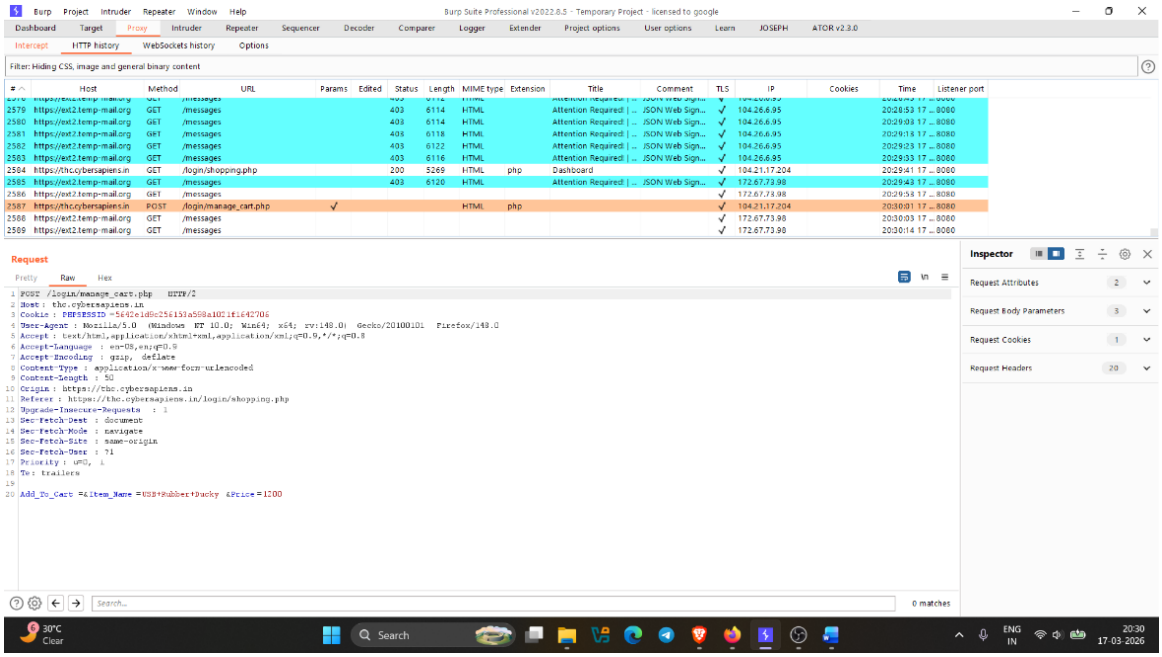
1. Navigate to the **Shopping** page of the application.
2. Select any product and click on the **Add to Cart** option.
3. Intercept the outgoing request using **Burp Suite**.
4. In the intercepted request, modify the product parameters such as:
   Item_Name=USB+Rubber+Ducky&Price=1200
   and replace them with arbitrary values.
5. Forward the modified request to the server.
6. Visit the **My Cart** page and observe that the manipulated product name and price are successfully added to the cart.
7. This demonstrates that the application does not properly validate product information on the server side, allowing unauthorized manipulation of product details.

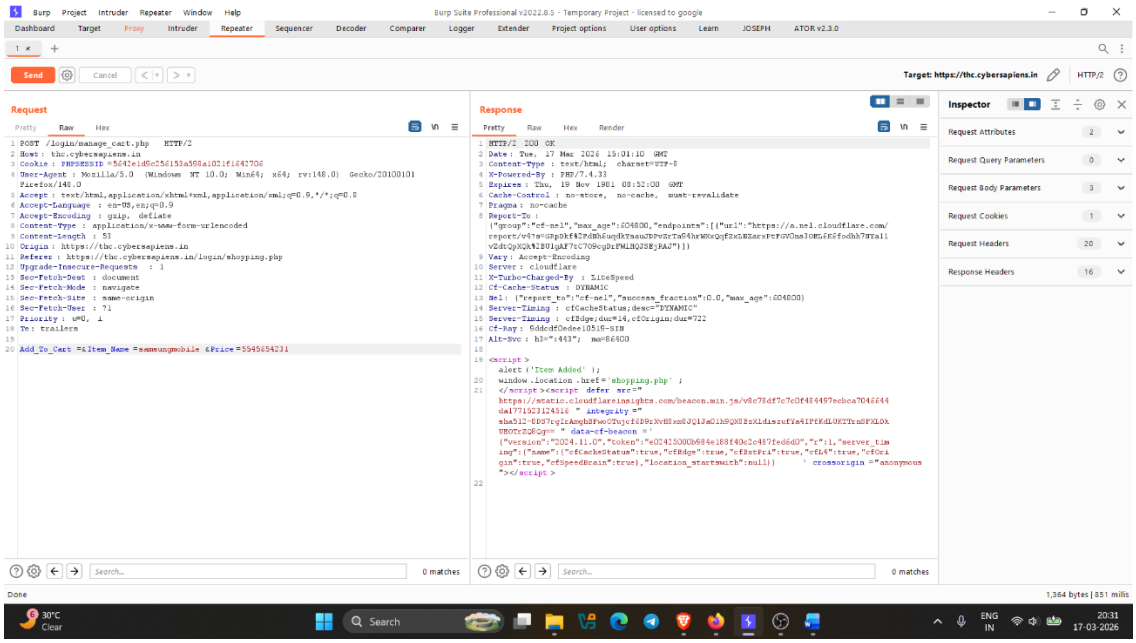
POC

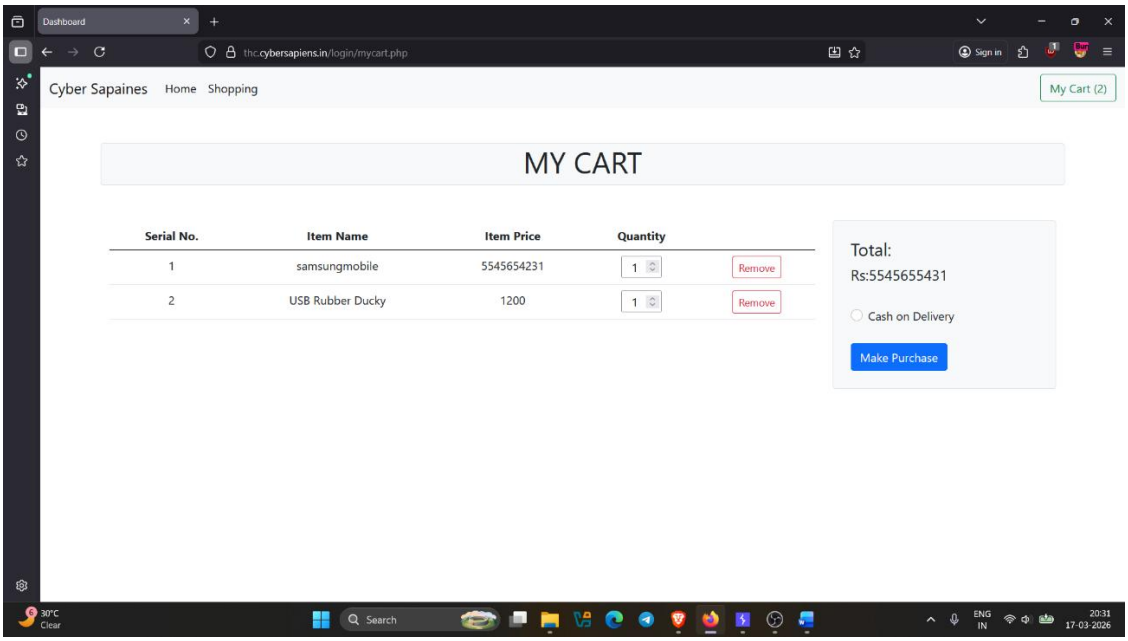
1. Please refer video - https://drive.google.com/drive/folders/1whSEZCixapU7iNsyF3a68_XuziO493V6?usp=drive_link

2. Screenshots









Impact

- Business logic vulnerabilities can vary in severity depending on how the affected functionality is used within the application. While some logic flaws may appear minor, they can potentially be leveraged by attackers to manipulate application behavior in unintended ways.
- If the vulnerability affects critical features such as authentication or authorization mechanisms, attackers may exploit it to bypass access controls or escalate privileges, gaining unauthorized access to sensitive data and system functionality. Additionally,

flaws within transaction-related processes may result in financial losses due to fraudulent purchases or manipulated transactions.

- Even when attackers cannot directly gain financial benefits, such vulnerabilities may still allow malicious users to disrupt business operations, compromise system integrity, or negatively impact the organization's reputation.

Suggested Mitigation / Remediation Actions

1. Define and Document Application Workflows
   Maintain detailed design documentation that outlines the flow of data and transactions within the application. This makes it easier to detect abnormal behavior and prevent logic flaws.

2. Ensure Code Clarity and Maintainability
   Writing clean and understandable code enables developers to easily identify errors in business logic and ensures that the intended functionality is properly implemented.

3. Provide Clear Documentation for Complex Logic
   For complicated processes, maintain clear documentation explaining the logic and assumptions behind each function to prevent misinterpretation.

4. Analyze Interdependencies Between Modules
   Evaluate how different components interact with one another and assess the potential impact if one component is manipulated by an attacker.

Reference:

https://portswigger.net/web-security/logic-flaws#what-is-the-impact-of-business-logic-vulnerabilities

https://cybertamarin.medium.com/how-i-found-an-idor-vulnerability-in-a-shopping-cart-api-02a379dc7d33

Vulnerability No.4

IDOR on Dashboard – Product Search

Bug Description

On search product from Dashboard, we can able to see the product. On changing product id from URL, we can navigate to other products as well. Like this, we can able to view products which are not yet released and in dev stage.

Threat

Insecure direct object references (IDOR) are a type of access control vulnerability that arises when an application uses user-supplied input to access objects directly

Vulnerable Website URL:

https://thc.cybersapiens.in/login/dashboard.php?get_id=1&search_by_id=

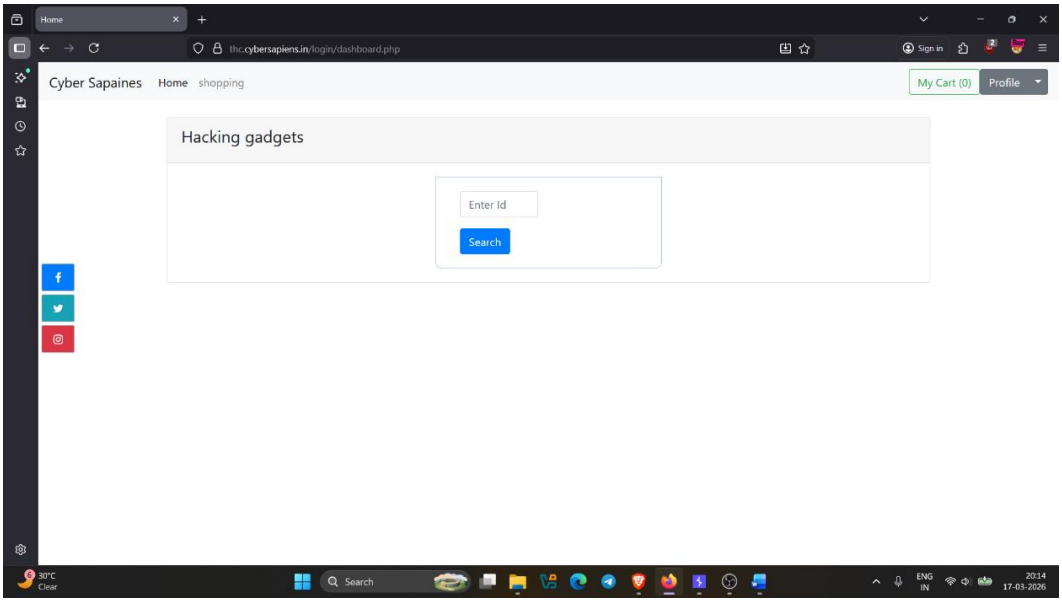
Steps to Reproduce

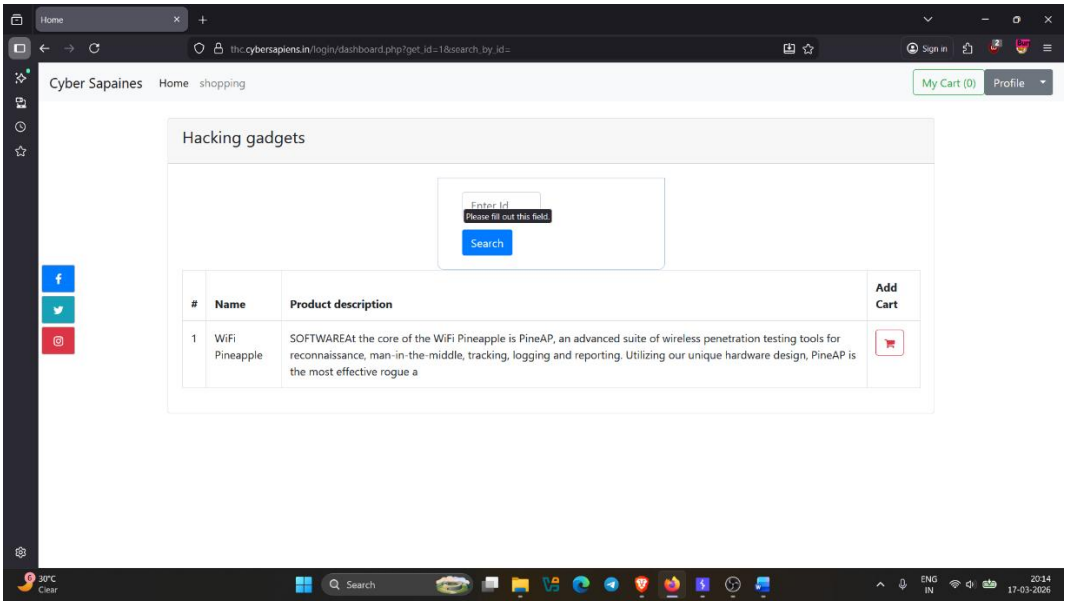
1. Log in and navigate to the **Dashboard**.
2. Use the search feature and search for product ID 1.
3. Observe the URL parameter:
   dashboard.php?get_id=1.
4. Modify the value of get_id to another number such as 2 or 3.
5. Reload the page and observe that different product information is displayed.

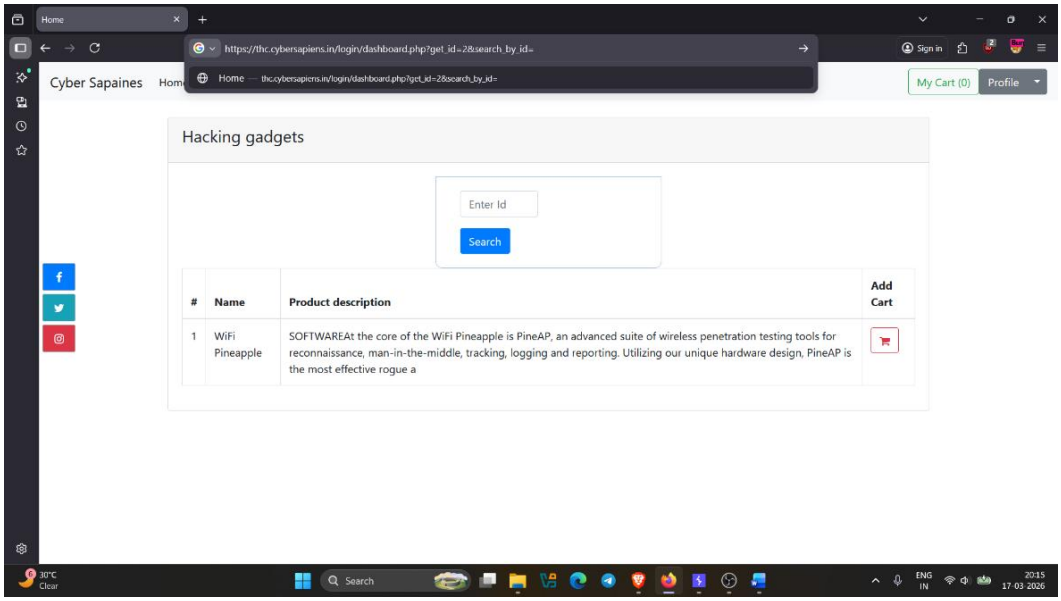
POC

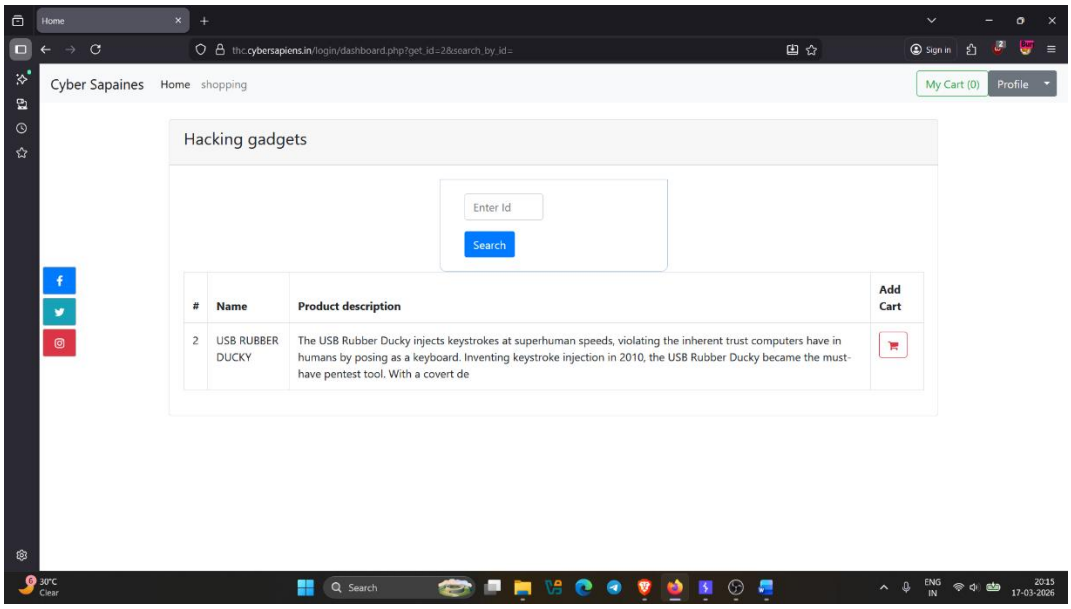
1. Please refer video -
https://drive.google.com/drive/folders/1whSEZCixapU7iNsyF3a68_XuziO493V6?usp=drive_link

2. Screenshots


Home
thc.cybersapiens.in/login/dashboard.php
Sign in
Cyber Sapaines
Home
shopping
My Cart (0)
Profile
Hacking gadgets
Enter Id
Search
30°C
Clear
Search
ENG
IN
20:14
17-03-2026


Home
thc.cybersapiens.in/login/dashboard.php?get_id=1&search_by_id=
Sign in
Cyber Sapaines
Home
shopping
My Cart (0)
Profile
Hacking gadgets
Enter Id
Please fill out this field.
Search
| Name | Product description | Add Cart
1 | WiFi Pineapple | SOFTWAREAt the core of the WiFi Pineapple is PineAP, an advanced suite of wireless penetration testing tools for reconnaissance, man-in-the-middle, tracking, logging and reporting. Utilizing our unique hardware design, PineAP is the most effective rogue a
30°C
Clear
Search
ENG
IN
20:14
17-03-2026





Impact

- Improper access control can have serious consequences for an application. If attackers are able to manipulate object identifiers, they may gain unauthorized access to restricted resources or sensitive data. In some cases, this could allow attackers to view confidential information, modify existing records, or delete important data.
- Furthermore, if the vulnerability affects critical functionalities, an attacker may perform actions beyond their intended privileges. In extreme scenarios, such weaknesses could potentially lead to administrative-level access or full compromise of application resources.

Remediation Actions

1. Enforce strict authorization checks for all requests involving sensitive data.
2. Implement **object-level access controls** to ensure users can only access resources they are permitted to view.
3. Perform validation on the server side rather than relying solely on client-side restrictions.
4. Avoid exposing sequential identifiers in URLs and use secure indirect references where possible.

Reference: https://corneacristian.medium.com/top-25-idor-bug-bounty-reports-ba8cd59ad331

Vulnerability No.5

File path traversal leads to reading local files

Bug Description

The application allows attackers to access local system files by manipulating file path inputs. Through this vulnerability, an attacker can retrieve sensitive files such as /etc/passwd, which should normally be inaccessible to users. This behavior suggests insufficient validation and sanitization of file path parameters.

Brief / Threat

Path traversal vulnerabilities arise when applications fail to properly restrict file path inputs. By using traversal sequences (such as ../), attackers can move outside the intended directory and access files stored elsewhere on the server. This may expose critical system files and potentially assist attackers in conducting further attacks.

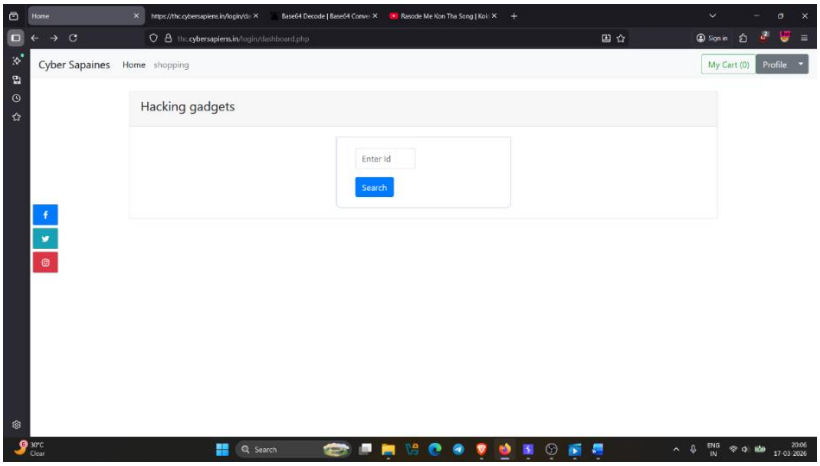
Vulnerable Website URL: https://thc.cybersapiens.in

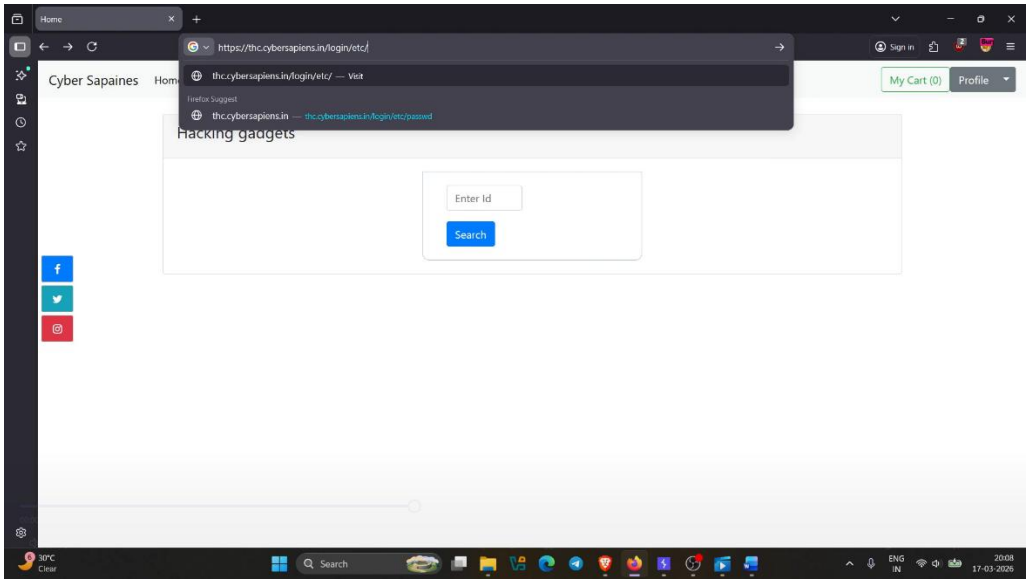
Steps to Reproduce

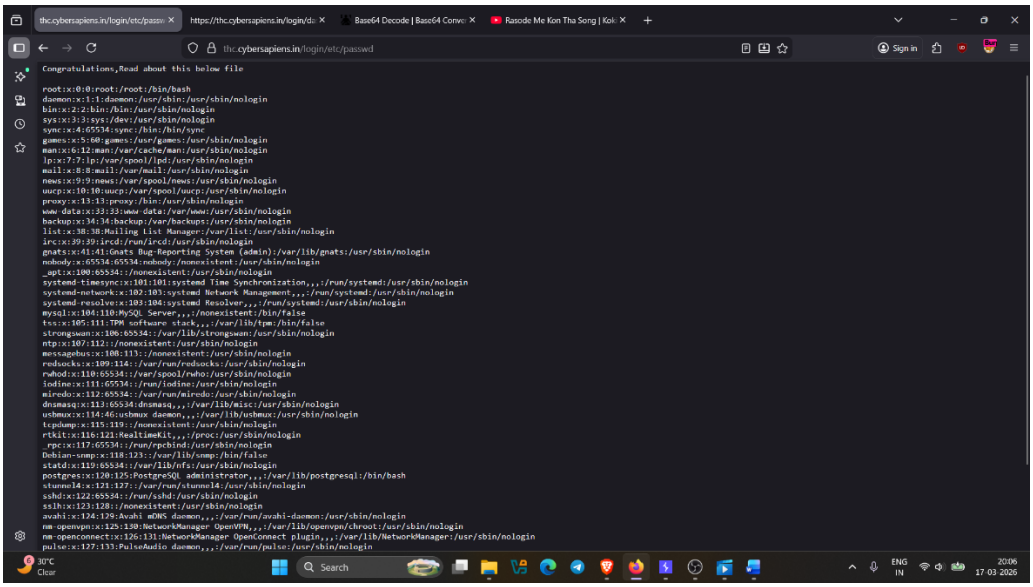
1. Navigate to the following URL: https://thc.cybersapiens.in/login/etc/passwd.
2. The application returns the contents of the **/etc/passwd** file.
3. This indicates that the application allows unauthorized access to local system files.

POC

1. Please refer video - https://drive.google.com/drive/folders/1whSEZCixapU7iNsyF3a68_XuziO493V6?usp=drive_link
2. Screenshots







Impact

A directory traversal vulnerability can expose sensitive files stored on the server, which may have serious security implications depending on the nature of the accessible data.

- **Sensitive Information Disclosure:** Attackers may retrieve confidential data such as user credentials, configuration files, financial information, or other private records stored on the system. This could result in data breaches or unauthorized disclosure of sensitive information.
- **Potential System Compromise:** Access to system files or configuration files may reveal critical details about the server environment. Attackers could leverage this information to escalate attacks, execute malicious code, or gain unauthorized control over the system.

- **Reputational and Business Impact:** Exposure of confidential data can damage the organization's reputation and reduce customer trust. For businesses handling sensitive information, such incidents may lead to legal consequences and financial losses.

Remediation Actions

1. Validate all user inputs to ensure they do not contain directory traversal patterns or unexpected characters.
2. Sanitize file paths before processing file requests to prevent navigation outside the permitted directory.
3. Avoid constructing file paths directly from user input. Instead, use predefined safe paths within the application.
4. Utilize secure programming techniques and safe file-handling functions such as realpath() or basename() to enforce path restrictions.
5. Implement proper file permission settings to limit access to sensitive server files.

Reference

https://medium.com/@zoningxtr/path-traversal-vulnerability-explained-how-hackers-climb-your-servers-directory-tree-c027af069407

Vulnerability No.6

Captcha Authentication Bypass

Bug Description
The CAPTCHA protection on the login page can be bypassed, allowing authentication without solving the CAPTCHA challenge. This indicates missing or improper server-side validation.

Threat
CAPTCHA is a security feature used to prevent automated bot activity by verifying that a user is human. If not properly implemented, it can be bypassed, enabling automated attacks such as brute-force or credential stuffing.

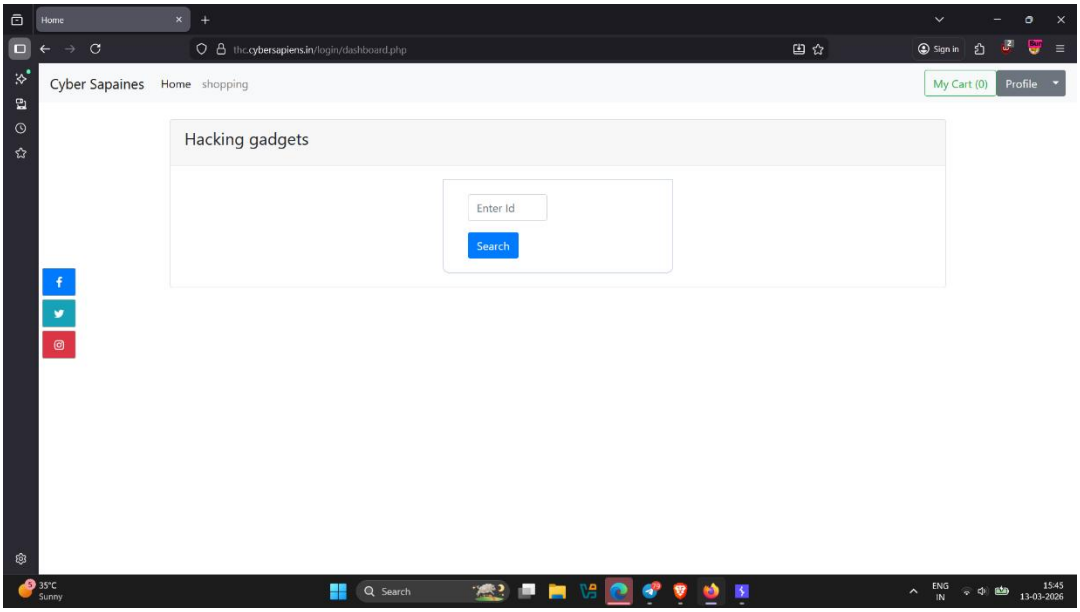
Vulnerable Website URL: https://thc.cybersapiens.in

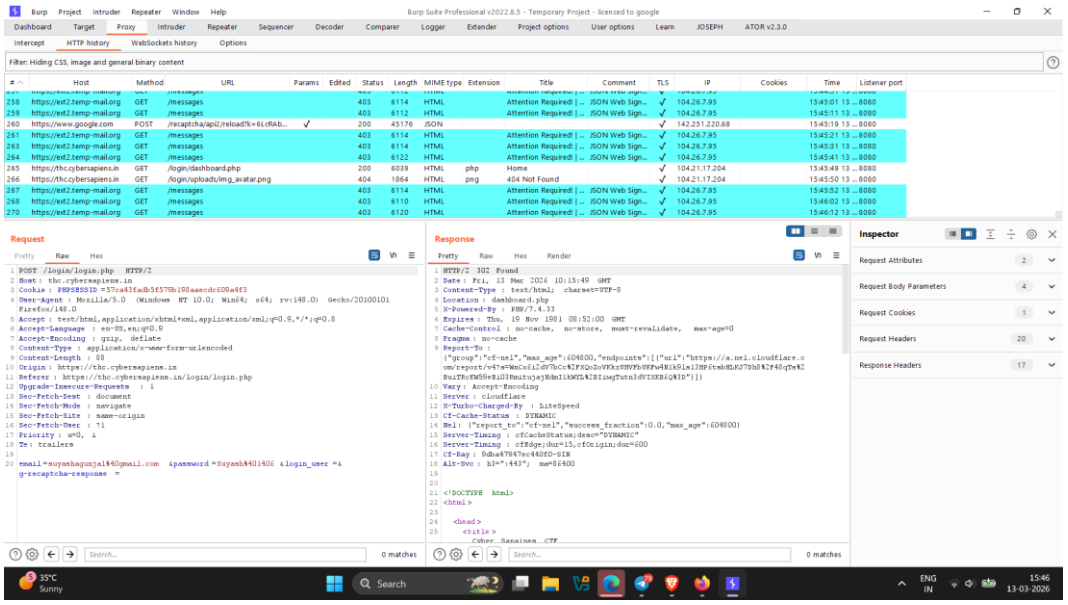
Steps to Reproduce

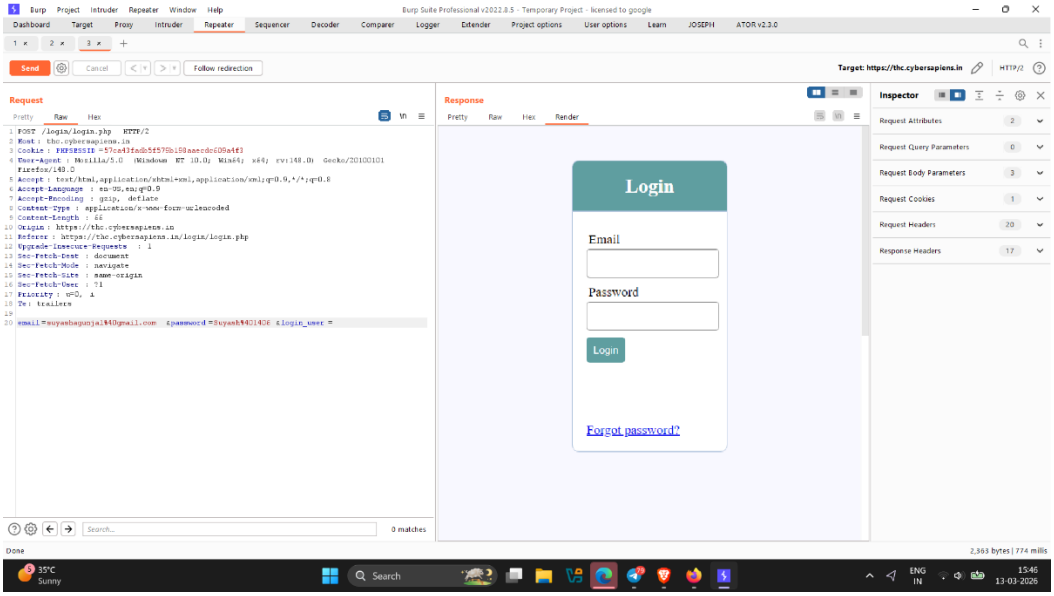
1. Access the application login page at: https://thc.cybersapiens.in/login/login.php.
2. Provide valid login credentials.
3. Use **Burp Suite Proxy** to capture the authentication request.
4. Modify the request by removing or tampering with the CAPTCHA response parameter.
5. Send the modified request to the server and observe that login is successful.
6. Alternatively, reload the login page and immediately submit the form before the CAPTCHA is fully rendered.
7. The application processes the login request successfully without validating the CAPTCHA.

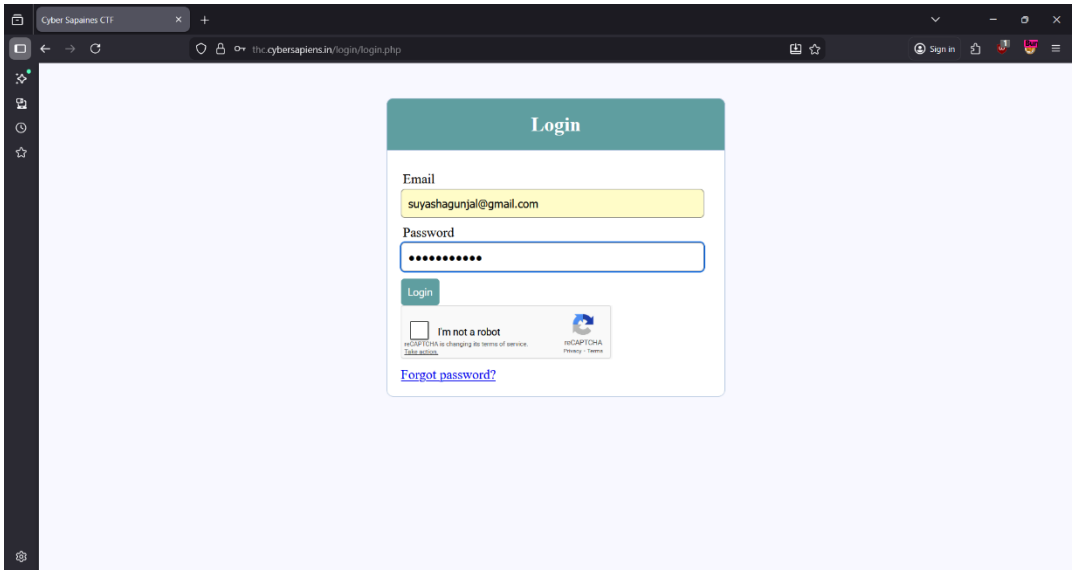
POC

1. Please refer video - https://drive.google.com/drive/folders/1whSEZCixapU7iNsyF3a68_XuziO493V6?usp=drive_link
2. Screenshots


Home
thc.cybersapiens.in/login/dashboard.php
Sign in
Cyber Sapaines
Home
shopping
My Cart (0)
Profile
Hacking gadgets
Enter Id
Search
35°C
Sunny
Search
ENG
IN
15:45
13-03-2026


Burp Project Intruder Repeater Window Help
Burp Suite Professional v2022.8.5 - Temporary Project - licensed to google
Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender Project options User options Learn JOSEPH ATOR v2.3.0
Intercept HTTP history WebSockets history Options
Filter: Hiding CSS, image and general binary content
Request
Response
Inspector
Request Attributes
Request Body Parameters
Request Cookies
Request Headers
Response Headers
35°C
Sunny
Search
ENG
IN
15:46
13-03-2026





Impact

Bypassing CAPTCHA allows attackers to perform unrestricted automated requests against the login functionality. This can lead to brute-force or credential stuffing attacks, as there are no effective controls limiting repeated login attempts.

Such behavior may also impact system performance and increase the likelihood of unauthorized access to user accounts.

Remediation Actions

1. Validate CAPTCHA responses on the server before processing login requests.
2. Implement rate limiting to restrict excessive login attempts.
3. Ensure CAPTCHA cannot be bypassed by removing or modifying request parameters.

4. Add additional protections such as account lockout policies or multi-factor authentication.

Reference : https://medium.com/@vishalsharma445500/unmasking-a-captcha-bypass-vulnerability-step-by-step-walkthrough-6131519a3788

Vulnerability No.7

CSRF – Logout Vulnerability

Bug Description

The application is vulnerable to Cross-Site Request Forgery (CSRF) on the logout functionality. An attacker can force a logged-in user to log out of their account by tricking them into visiting a malicious link or page. This occurs because the logout request is processed without validating the origin or requiring any anti-CSRF protection.

Threat

Cross-Site Request Forgery (CSRF) is a web vulnerability that allows an attacker to perform unauthorized actions on behalf of an authenticated user. It exploits the trust that a web application has in the user's browser. If proper protections such as CSRF tokens are not implemented, attackers can craft malicious requests that are automatically executed by the victim's browser using their active session.

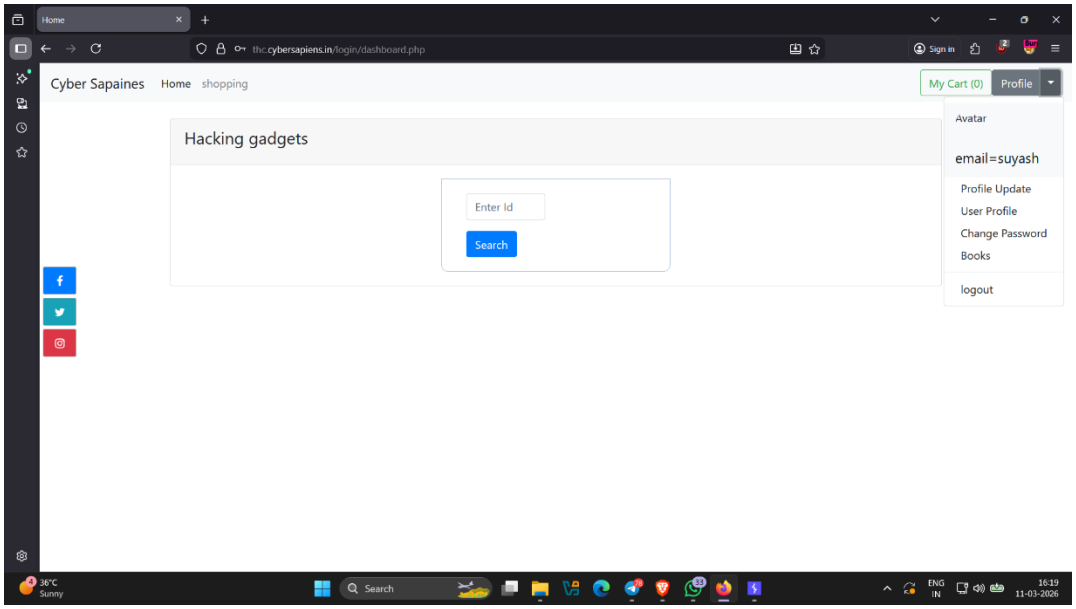
Vulnerable Website URL: https://thc.cybersapiens.in

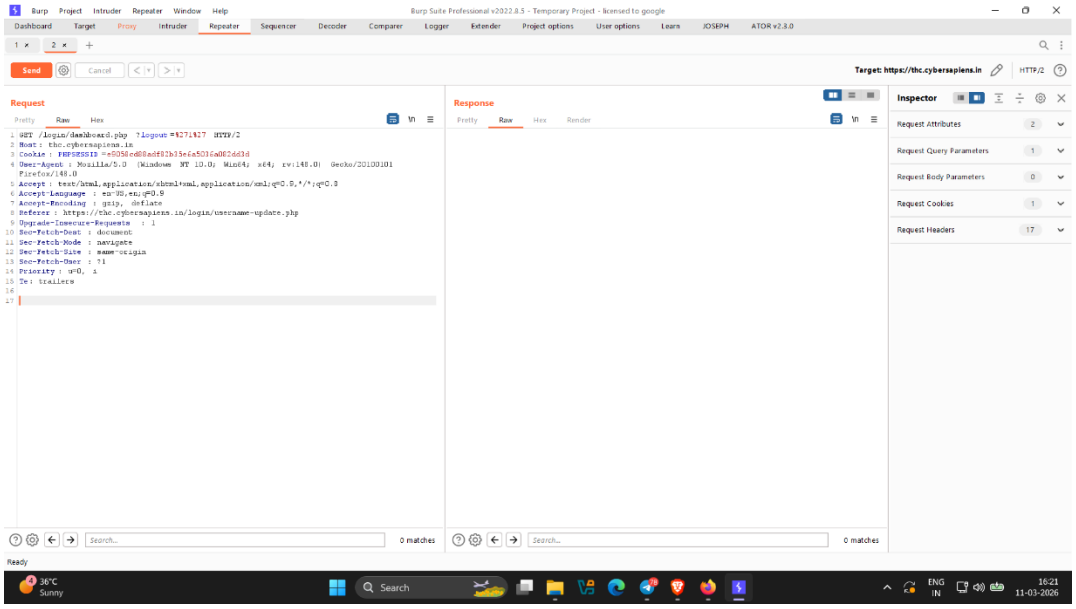
Steps to Reproduce

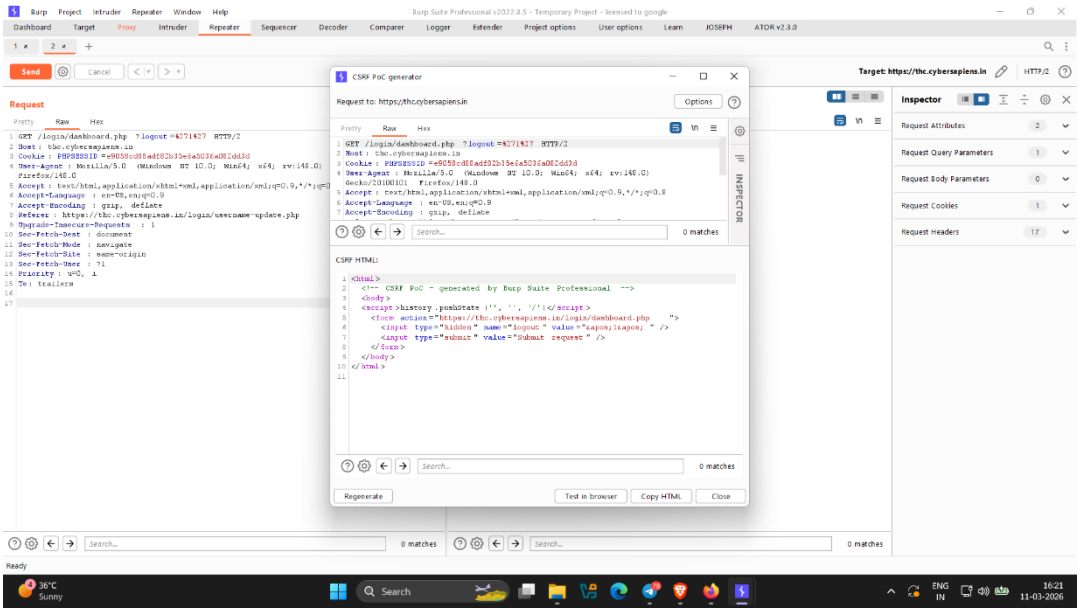
1. Log in to the application using valid credentials.
2. Identify the logout request (for example via Burp Suite or browser developer tools).
3. Observe that the logout request does not contain any CSRF token or validation parameter.
4. Create a malicious HTML PoC
5. Host or open this HTML file in a browser.
6. While the victim is logged into the application, trick them into visiting this page.
7. Observe that the user is automatically logged out without their consent.

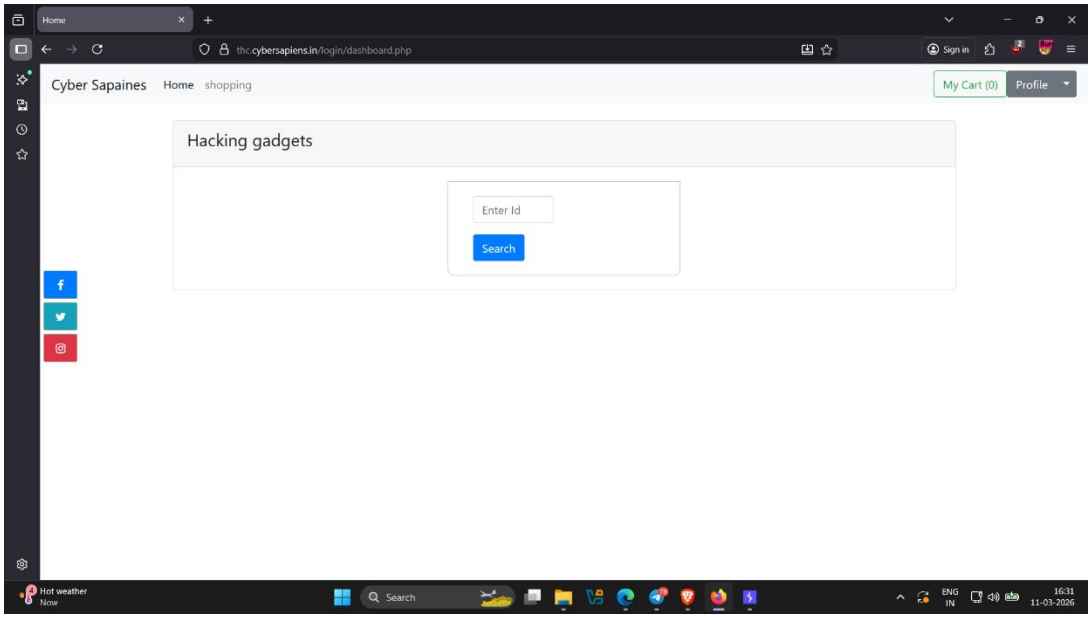
POC

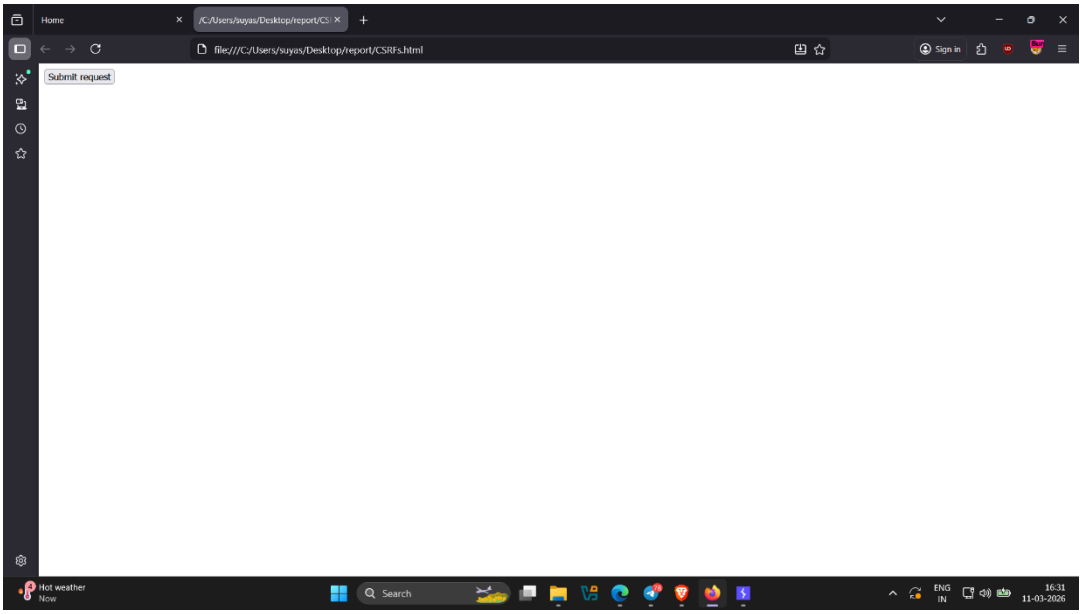
1. Please refer video - https://drive.google.com/drive/folders/1whSEZCixapU7iNsyF3a68_XuziO493V6?usp=drive_link
2. Screenshots

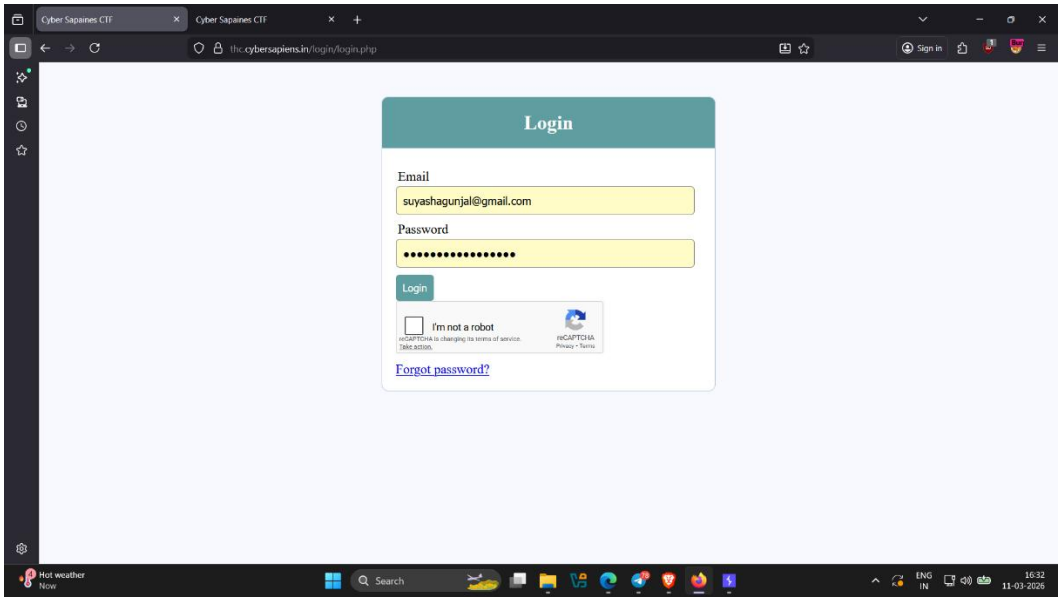

Home
thc.cybersapiens.in/login/dashboard.php
Cyber Sapaines
Home
shopping
My Cart (0)
Profile
Hacking gadgets
Enter Id
Search
Avatar
email=suyash
Profile Update
User Profile
Change Password
Books
logout


Burp Project Intruder Repeater Window Help
Burp Suite Professional v2022.8.5 - Temporary Project - licensed to google
Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender Project options User options Learn JOSEPH ATOR v2.3.0
Send
Cancel
Target: https://thc.cybersapiens.in
HTTP/2
Request
Response
Inspector
Request Attributes
Request Query Parameters
Request Body Parameters
Request Cookies
Request Headers
Ready


CSRF PoC generator
Request to: https://thc.cybersapiens.in
Options
CSRF HTML:
Regenerate
Test in browser
Copy HTML
Close
Ready


Home
thc.cybersapiens.in/login/dashboard.php
Cyber Sapaines
Home
shopping
My Cart (0)
Profile
Hacking gadgets
Enter Id
Search


Home
file:///C:/Users/suyas/Desktop/report/CSRFs.html
Submit request


Cyber Sapaines CTF
thc.cybersapiens.in/login/login.php
Login
Email
suyashagunjal@gmail.com
Password
Login
I'm not a robot
Forgot password?

Impact

- Attackers can force users to log out of their accounts without interaction.
- This may disrupt user sessions and degrade user experience.
- Can be combined with other attacks (e.g., login CSRF, phishing) to increase effectiveness.
- Indicates lack of proper request validation, which may exist in other critical functionalities as well.

Remediation Actions

1. Implement CSRF Tokens
   Include a unique, unpredictable CSRF token in all sensitive requests and validate it on the server side.
2. Validate Request Origin
   Verify the Origin and Referer headers to ensure requests are coming from trusted sources.
3. Use SameSite Cookies
   Set session cookies with the SameSite attribute (Strict or Lax) to prevent cross-site request execution.
4. Require User Interaction
   For sensitive actions like logout, consider requiring explicit user interaction (e.g., confirmation button).

Reference: https://medium.com/@raia39499/a-deep-dive-into-logout-csrf-vulnerability-e40e1fa7f465

Vulnerability No.8

CSRF Password Change Vulnerability

Bug Description

The application is vulnerable to Cross-Site Request Forgery (CSRF) in the password change functionality. An attacker can craft a malicious request that allows changing the password of a logged-in user without their consent. This occurs due to the absence of CSRF protection in the request.

Threat

Cross-Site Request Forgery (CSRF) is a web security vulnerability that allows attackers to perform unauthorized actions on behalf of an authenticated user. It exploits the trust a web application places in the user's browser. If proper protections such as CSRF tokens are not implemented, attackers can trick users into executing unintended actions like changing account settings.

Vulnerable Website URL: https://thc.cybersapiens.in

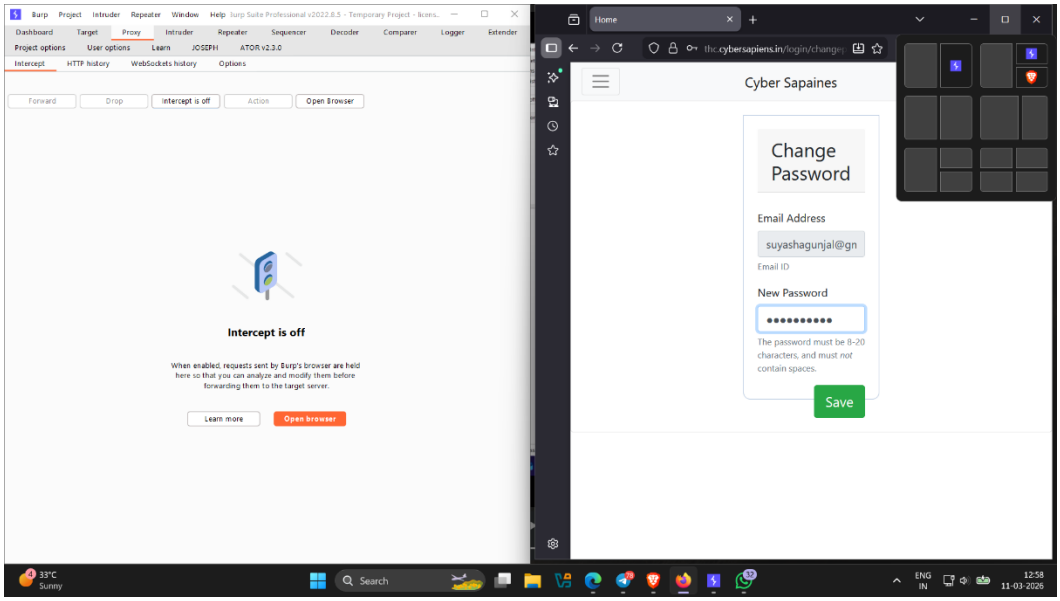
Steps to Reproduce

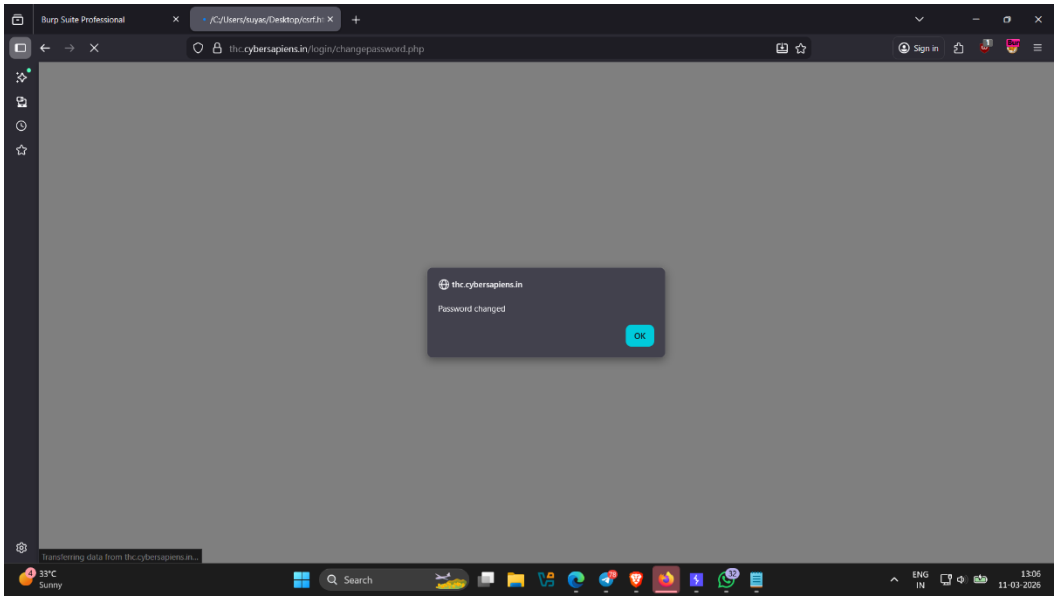
1. Log in to the application and navigate to the **Change Password** page: https://thc.cybersapiens.in/login/changepassword.php.
2. Change the password and intercept the request using **Burp Suite**.
3. Observe that the request is sent to /login/changepassword.php with parameters like email and password, but **no CSRF token is present**.
4. Right-click the request in Burp Suite and select:
   Engagement tools → Generate CSRF PoC, then save the generated HTML file.
5. Open the generated PoC file in a browser while the user is logged in.
6. Observe that the password is changed successfully without user consent, confirming the CSRF vulnerability.

POC

1. Please refer video -
https://drive.google.com/drive/folders/1whSEZCixapU7iNsyF3a68_XuziO493V6?usp=drive_link

2. Screenshots






```
<html>
  <!-- CSRF PoC - generated by Burp Suite Professional -->
  <body>
  <script>history.pushState('', '', '/')</script>
    <form action="https://thc.cybersapiens.in/login/changepassword.php" method="POST">
      <input type="hidden" name="email" value="suyashagunjal&#64;gmail&#46;com" />
      <input type="hidden" name="password" value="Testing&#64;123" />
      <input type="hidden" name="submit" value="" />
      <input type="submit" value="Submit request" />
    </form>
  </body>
</html>
```

Impact

- Account Takeover: An attacker can change the victim's password and gain full access to their account.
- Loss of Access: The legitimate user may be locked out of their account.
- Unauthorized Actions: Sensitive account operations can be performed without user consent.
- Phishing Attack Vector: The vulnerability can be exploited through malicious links or websites.
- Security Control Failure: Indicates missing protection for critical functionalities.

Remediation Actions

1. Implement CSRF Tokens
   Add a unique, unpredictable CSRF token to all sensitive requests and validate it on the server side.
2. Validate Origin and Referer Headers
   Ensure requests are coming from trusted sources.
3. Use SameSite Cookies
   Set session cookies with SameSite=Strict or Lax to prevent cross-site request execution.
4. Require Re-authentication
   Ask users to enter their current password before allowing password changes.
5. Avoid Trusting Client-Side Data
   Perform all validations on the server side to prevent request manipulation.

Reference: https://parasarora06.medium.com/csrf-on-change-password-854ba02590df

Vulnerability No.9

Internal Broken Link Hijacking

Bug Description

After authentication, the application contains multiple **broken or invalid links** accessible at: https://thc.cybersapiens.in/login/.
These links lead to non-functional or missing resources, indicating improper link management within the application.

Threat

Broken link vulnerabilities occur when an application references URLs or resources that are no longer valid or properly maintained. Such links may point to missing pages, expired resources, or incorrectly configured endpoints. While often overlooked, broken links can expose unintended behaviors and may be leveraged by attackers for malicious activities such as phishing, defacement, or injection attacks.

Vulnerable Website URL: **https://thc.cybersapiens.in/login/**

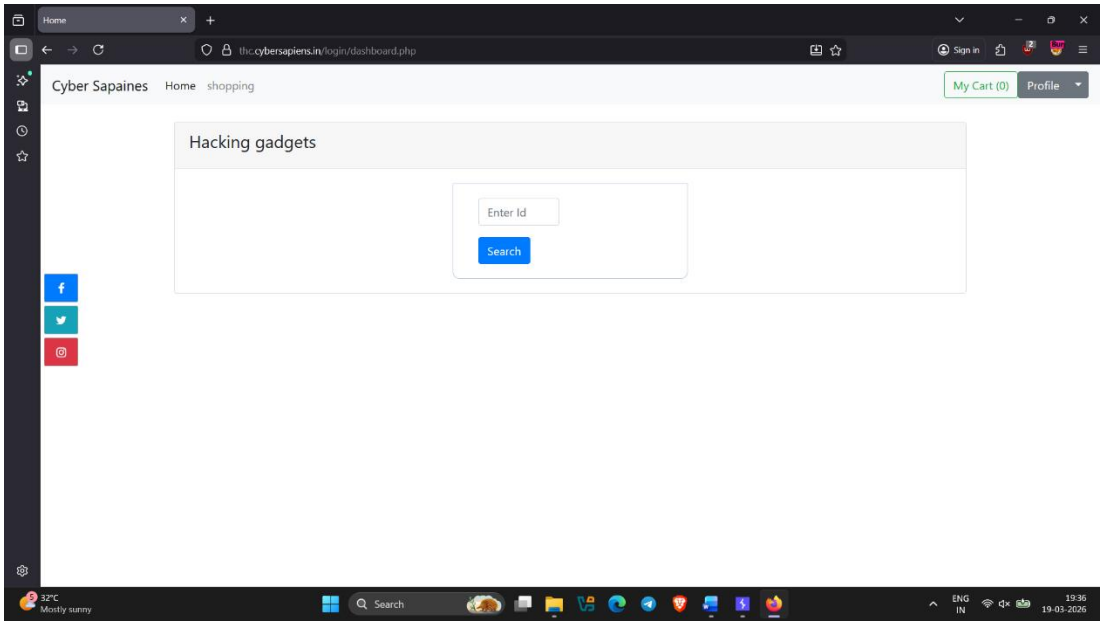
Steps to Reproduce

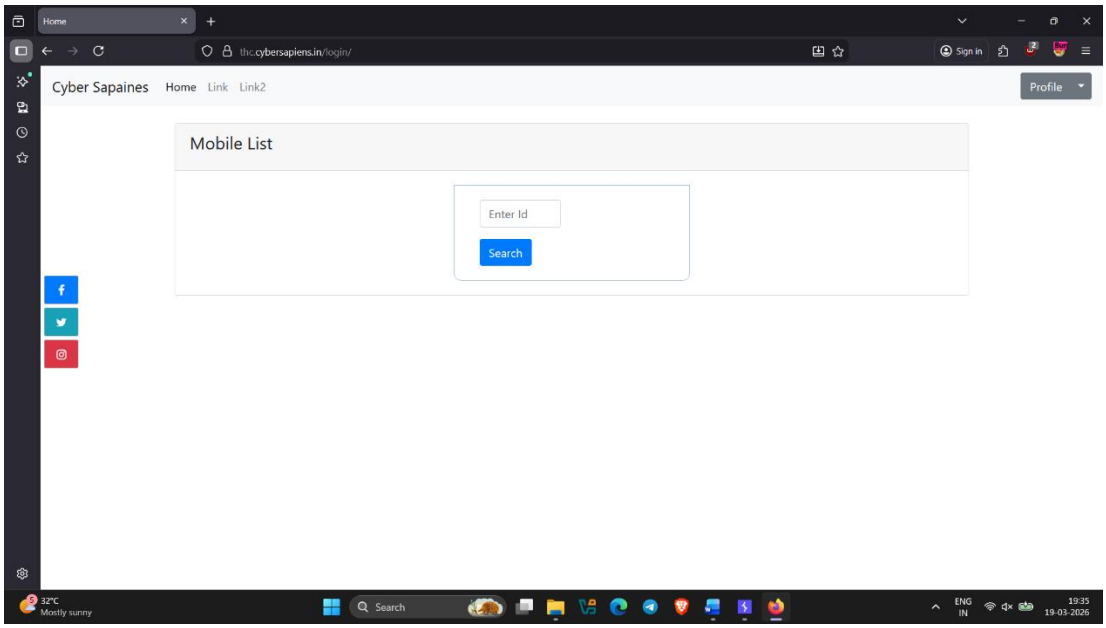
1. Log in to the application using valid credentials.
2. Navigate to the following URL:
   https://thc.cybersapiens.in/login/.
3. Observe the presence of unexpected or unrelated content on the page (e.g., mobile list and descriptions).
4. Identify broken or expired links labeled as **Link1** and **Link2**.
5. Click on these links and observe that they lead to invalid or non-functional pages.
6. These expired links could potentially be taken over by an attacker to host malicious or phishing content.

POC

1. Please refer video -
https://drive.google.com/drive/folders/1whSEZCixapU7iNsyF3a68_XuziO493V6?usp=drive_link

2. Screenshots





Impact

- **User Experience Degradation:** Users may encounter errors or inaccessible pages, reducing trust in the application.
- **Potential Security Risks:** Attackers may exploit broken links to host malicious content or perform phishing attacks.
- **Information Exposure:** Misconfigured or outdated links may reveal internal paths or application structure.
- **Attack Surface Expansion:** Broken endpoints may be used as entry points for further exploitation such as XSS or redirection attacks.

Remediation Actions

- **Regular Link Validation**
  Perform periodic checks to identify and fix broken or invalid links within the application.
- **Remove or Update Invalid References**
  Ensure all links point to valid and active resources.
- **Implement Proper Error Handling**
  Configure user-friendly error pages instead of exposing raw errors or broken responses.
- **Monitor External Dependencies**
  Validate third-party or external links to ensure they remain secure and accessible.
- **Use Automated Tools**
  Utilize scanners or monitoring tools to detect broken links during development and production.

Reference : https://medium.com/bugbountywriteup/404-to-fortune-how-a-broken-link-uncovered-internal-apis-staged-dev-dumps-235aa80c2406

Vulnerability No.10

External Broken Link Hijacking

Bug Description

There is a broken link of Instagram at https://thc.cybersapiens.in/login/ . It is https://www.instagram.com/Cyber-sapiens/ but it should be https://www.instagram.com/cybersapiens1010/ as per other pages

Threat

The attacker takes advantage of invalid external links. If your website or web application contains outbound links or is loading resources from external URLs and those resources are no longer available (for example, due to an expired domain), attackers can use these links to perform defacement, impersonation, phishing, or cross-site scripting attacks.

Vulnerable URL:

https://thc.cybersapiens.in/login/

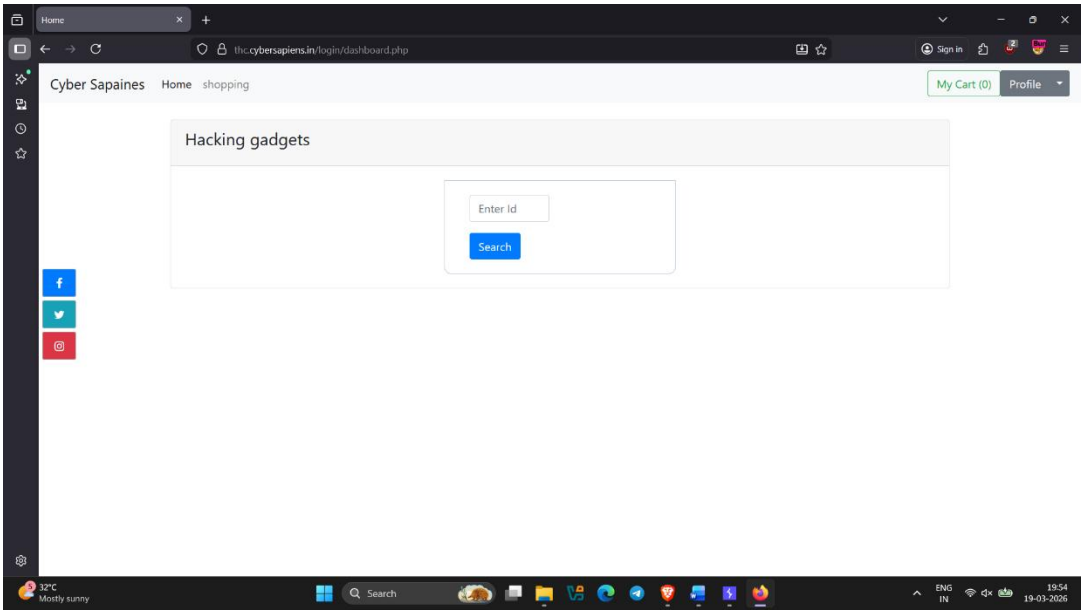
Steps to Reproduce

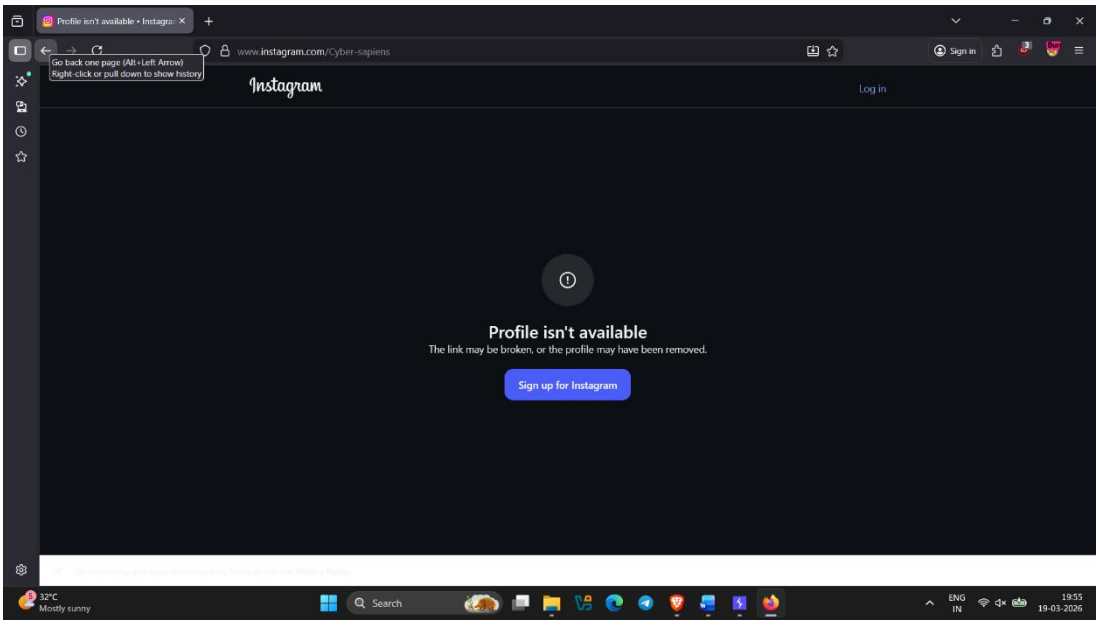
1. Navigate to the following URL: https://thc.cybersapiens.in/login/books.php.
2. Click on the **Instagram link** displayed on the left side of the page.
3. Observe that the link redirects to a non-existent Instagram profile: https://www.instagram.com/Cyber-sapiens/.
4. Register a new Instagram account using the same username (**Cyber-sapiens**).
5. After account creation, revisit the application link.
6. Observe that users are now redirected to the newly created account, which can be used to host misleading or malicious content.

POC

1. Please refer video - https://drive.google.com/drive/folders/1whSEZCixapU7iNsyF3a68_XuziO493V6?usp=drive_link

2. Screenshots





Impact

Broken link hijacking can be exploited by attackers to perform various malicious activities by leveraging the application's trust and domain reputation.

- Phishing Attacks: Attackers can create malicious pages and trick users into believing they are legitimate, leading to credential theft or sensitive data exposure.
- Malware Distribution: Users may be redirected to attacker-controlled pages hosting malicious content or downloads.
- Brand Reputation Damage: Misuse of trusted application links can reduce user trust and harm the organization’s reputation.

- User Manipulation: Attackers can spread misinformation or redirect users to unintended content.
- Increased Attack Surface: Broken external links provide an entry point for social engineering and further exploitation.

Remediation Actions

1. Validate External Links
   Ensure that all external links used in the application point to valid and controlled resources.
2. Remove or Update Broken Links
   Regularly review and update outdated or non-functional links to prevent misuse.
3. Avoid Hardcoding External URLs
   Use controlled and verified references for third-party links instead of static or outdated URLs.
4. Monitor External Resources
   Continuously monitor linked external platforms to ensure they are still owned and managed by the organization.
5. Implement Warning Mechanisms
   Notify users when they are being redirected to external websites to reduce the risk of phishing.

Reference: https://shahjerry33.medium.com/broken-link-hijacking-mr-user-agent-cd124297f6e6

Thank You